

# Baseline security practices

Minimum controls common across the most-referenced IT security standards, organized by dependency tier.

**Note — AI outputs are probabilistic, not verified truth. Treat as input to your reasoning, not a substitute.**  
Synthesized using **Claude Opus 4.7** (Anthropic). Knowledge cutoff: Jan 2026. Document generated: 2026-05-28 UTC. Tools used during creation: **web\_search** (to verify current standard versions) and **visualize/pdf** tooling. Sampling parameters are not exposed to the model. The 17 controls below are a cross-standard intersection synthesized by Claude, not a quotation from any single standard — references in each card point to the closest analogue in each standard, not exact equivalents.

## Tier 1 — Foundation (know what you have, decide who decides)

|                                                                                                                                                                        |                                                                                                                                        |                                                                                                                                                             |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Governance &amp; policy</b><br>Roles, risk strategy, accountability<br>ISO 27001 cl. 5 · CSF GV · 800-53 PM · PCI 12 · HIPAA §164.308(a)(1) · SOC 2 CC1 · COBIT EDM | <b>Asset inventory</b><br>Hardware, software, data<br>CIS 1-2 · ISO 27002 A.5.9 · CSF ID.AM · 800-171 3.4.1 · PCI 12.5.1 · 800-53 CM-8 | <b>Risk assessment</b><br>Threats, classification, review<br>ISO 27001 cl. 6.1 · HIPAA §164.308(a)(1)(ii)(A) · PCI 12.3 · 800-53 RA · SOC 2 CC3 · CSF ID.RA |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|

## Tier 2 — Protection (reduce the attack surface, harden the targets)

|                                                                                                                                                        |                                                                                                                                                      |                                                                                                                                                    |
|--------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Identity &amp; access</b><br>Unique IDs, least privilege<br>PCI 7-8 · HIPAA §164.312(a) · ISO 27002 A.5.15-5.18 · CIS 5-6 · 800-171 3.1 · CSF PR.AA | <b>Strong authentication</b><br>MFA on admin and remote<br>PCI 8.4 (v4.0.1) · 800-171 3.5.3 · CIS 6.3-6.5 · CSF PR.AA-03 · HIPAA NPRM 2025 · 800-63B | <b>Encryption</b><br>In transit and at rest<br>PCI 3-4 · HIPAA §164.312(a)(2)(iv), (e) · ISO 27002 A.8.24 · 800-171 3.13.8/.11 · CSF PR.DS         |
| <b>Patch &amp; vuln mgmt</b><br>Timely critical patches<br>PCI 6.3 · CIS 7 · ISO 27002 A.8.8 · 800-171 3.14.1 · 800-53 SI-2 · CSF PR.PS                | <b>Secure configuration</b><br>No defaults, hardened<br>PCI 2 · CIS 4 · ISO 27002 A.8.5 · 800-171 3.4.2 · 800-53 CM-6 · CSF PR.FS-01                 | <b>Network segmentation</b><br>Boundary, firewalls, zoning<br>PCI 1 · ISO 27002 A.8.20-8.22 · CIS 12 · 800-171 3.13.1 · 800-53 SC-7 · CSF PR.IR    |
| <b>Malware protection</b><br>Endpoint, email filters<br>PCI 5 · ISO 27002 A.8.7 · CIS 10 · HIPAA §164.308(a)(5)(ii)(B) · 800-53 SI-3                   | <b>Backups</b><br>Tested, offline or immutable<br>ISO 27002 A.8.13 · CIS 11 · HIPAA §164.308(a)(7)(ii)(A) · 800-53 CP-9 · CSF PR.DS-11               | <b>Security awareness</b><br>Phishing, role-based training<br>PCI 12.6 · HIPAA §164.308(a)(5) · ISO 27002 A.6.3 · CIS 14 · 800-171 3.2 · CSF PR.AT |

## Tier 3 — Assurance (verify, detect, recover)

|                                                                                                                                       |                                                                                                                                                   |                                                                                                                                                                 |
|---------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Audit logging</b><br>Auth, admin, system events<br>PCI 10 · ISO 27002 A.8.15 · HIPAA §164.312(b) · 800-171 3.3 · CIS 8 · 800-53 AU | <b>Monitoring &amp; detection</b><br>Review, alert on anomalies<br>CSF DE.CM, DE.AE · PCI 10.4 · SOC 2 CC7.2 · ISO 27002 A.8.16 · 800-53 SI-4     | <b>Incident response</b><br>Plan, roles, notification path<br>ISO 27002 A.5.24-5.27 · HIPAA §164.308(a)(6) · PCI 12.10 · 800-171 3.6 · CSF RS · SOC 2 CC7.3-7.5 |
| <b>Vulnerability scanning</b><br>Periodic external + internal<br>PCI 11.3 · CIS 7.5-7.6 · 800-171 3.11.2 · 800-53 RA-5 · CSF IL.RA-01 | <b>Third-party review</b><br>Vendor risk, contract clauses<br>ISO 27002 A.5.19-5.23 · HIPAA BAAs · PCI 12.8 · SOC 2 CC9.2 · CSF GV.SC · 800-53 SR |                                                                                                                                                                 |

## Standards referenced (with versions and sources)

**ISO/IEC 27001:2022** — Information security management systems — Requirements. Published Oct 2022.  
<https://www.iso.org/standard/27001>

**ISO/IEC 27002:2022** — Information security controls. Published Feb 2022; 93 controls in 4 themes (Organizational, People, Physical, Technological).  
<https://www.iso.org/standard/75652.html>

**NIST Cybersecurity Framework (CSF) 2.0** — Published Feb 2024. Six functions: Govern, Identify, Protect, Detect, Respond, Recover.  
<https://www.nist.gov/cyberframework>

**NIST SP 800-53 Rev. 5** — Security and Privacy Controls for Information Systems and Organizations. Released Sept 2020; updates through 2023 (incl. patch release 5.1.1).  
<https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final>

**NIST SP 800-171 Rev. 3** — Protecting Controlled Unclassified Information in Nonfederal Systems. Published May 2024; 97 requirements across 17 families. DoD contractor compliance (via CMMC) currently still aligned to Rev. 2; Rev. 3 enforcement expected via rulemaking through 2026–2027.  
<https://csrc.nist.gov/pubs/sp/800/171/r3/final>

**PCI DSS v4.0.1** — Payment Card Industry Data Security Standard. Released June 2024 (minor errata over v4.0, March 2022). v3.2.1 retired March 2024.  
[https://www.pcisecuritystandards.org/document\\_library/](https://www.pcisecuritystandards.org/document_library/)

**HIPAA Security Rule** — 45 CFR Part 164, Subpart C. Current rule last substantively updated 2013. NPRM published Jan 6, 2025 (90 FR 800) to strengthen requirements (mandatory MFA, encryption, asset inventory, etc.); final rule on HHS regulatory agenda for May 2026 (not yet finalized as of this document's creation date).  
<https://www.hhs.gov/hipaa/for-professionals/security/index.html>

**AICPA SOC 2 Trust Services Criteria** — TSP Section 100, 2017 criteria with 2022 revisions. Categories: Security (Common Criteria CC1–CC9), Availability, Confidentiality, Processing Integrity, Privacy.  
<https://www.aicpa-cima.com/topic/audit-assurance/audit-and-assurance-greater-than-soc-2>

**CIS Critical Security Controls v8.1** — Released June 2024. 18 controls, 153 safeguards, 3 Implementation Groups (IG1–IG3). Includes Govern function alignment to CSF 2.0.  
<https://www.cisecurity.org/controls/v8-1>

**OWASP Top 10:2021** — Web application risk awareness document. Next revision in development as of this document's creation date.  
<https://owasp.org/Top10/>

**NIST SP 800-63B** — Digital Identity Guidelines: Authentication and Lifecycle Management. Referenced for authentication baselines.  
<https://pages.nist.gov/800-63-2/>

**COBIT 2019 (ISACA)** — Governance and management of enterprise I&T.  
<https://www.isaca.org/resources/cobit>